POVRŠINA NAPADA – Zadatak 3

KORISNICI I EKSTERNI SISTEMI

1.1 Eksterni korisnici

- Putnici - Fizička lica koja koriste MegaTravel web sajt da bi pretraživali, rezervisali i plaćali turističke usluge.

1.2 Interni korisnici

- Zaposleni / Agenti - Interni portali i admin paneli – upravljanje rezervacijama, klijentima, finansijskim transakcijama
- Administratori sistema - Direktan pristup serverima i bazama podataka

1.3 Eksterni sistemi

- Partneri(Hoteli, Aerodromi) - API integracije – razmena podataka o dostupnosti, cenama i rezervacijama
- Sistemi za Plaćanje - API pozivi za procesiranje kreditnih/debitnih kartica i online transakcija
- Email servisi - Slanje potvrda rezervacija, obaveštenja i promotivnih poruka korisnicima
- Državni / Regulatorni sistemi – Poreska prijava, razmena putnih i carinskih podataka

ULAZNE TAČKE SISTEMA I POVRŠINA NAPADA

2.1 Web sajt

- HTTPS Endpoint - Javno dostupan. Svaki internet korisnik može slati HTTP zahteve. Ulazna tačka za SQL Injection, XSS, CSRF, brute force napade.
- Forma za Registraciju / Login - Dostupna svima. Podložna napadima na autentifikaciju, credential stuffing i account takeover.
- Pretraga i Filteri - Dostupna svima. Potencijalna meta za injection napade i DoS / DDoS kroz složene i mnogobrojne upite.

- Forma za Plaćanje - Autentifikovani korisnici. Visoko osetljiva – rizik od krađe platnih podataka (skimming).

2.2 Interni Admin Portal

- Admin Web Interface - Interni zaposleni. Ako je dostupan sa interneta – visok rizik. Privilegovane operacije nad podacima klijenata.
- VPN / Remote Access – Zaposleni na daljinu. Rizik od man-in-the-middle napada.

2.3 API za Partnere

- REST API Endpointi - Partneri sa API ključevima. Rizik od API key leakage, nedovoljne autorizacije i zloupotrebe podataka.

2.4 Sistemi za Plaćanje

- Payment Gateway API - Interni sistemi plaćanja. Man-in-the-middle, replay napadi, manipulacija iznosom transakcije.
- Callback / Notifikacijski URL - Povratni pozivi od payment providera. Rizik od lažnih callback-ova.

2.5 Email Servis

- Email Server / SMTP - Interni i eksterni. Phishing, email spoofing, zloupotreba reset lozinke

2.6 Baza Podataka i Interni Servisi

- Database Port - Interni servisi. Direktni napadi ako je pogrešno eksponovan, SQL injection iz aplikacionog sloja.
- Config Store / Environment Variables - Interni procesi. Kompromitovanje configa otkriva konekcione stringove, API ključeve i tajne.